



ТЕХНИЧЕСКИ УНИВЕРСИТЕТ – СОФИЯ



ФАКУЛТЕТ ПО КОМПЮТЪРНИ СИСТЕМИ И ТЕХНОЛОГИИ

КОМПЮТЪРНО И СОФТУЕРНО ИНЖЕНЕРСТВО

Какво представлява ransomware?

Стратегии и защита от ransomware.

Реферат по

„Програмни технологии за сигурен код“

Съставил: Ангел Любомиров Стойнов

Факултетен номер: 121222150

Група: 40

Съдържание

Въведение	3
История на Ransomware	4
Еволюция на Ransomware	5
1. Ранна фаза на Ransomware	5
2. Ransomware използващ RSA криптиране	6
3. Spear phishing Ransomware	8
4. Ransomware в Android базирани системи	10
5. Big Game Hunting (BGH) и Ransomware	11
Ransomware в България	12
Ролята на AI в Ransomware атаките	13
Имплементация на Ransomware	14
Демонстрация на Ransomware	16
Съдържание на текстовите файлове преди криптирането:	16
Стартиране на демото:	17
Потърпевшият е заплатил откупа:	18
QR code към имплементацията:	19
Стратегии и защита от ransomware	20
1. Подготовка за Ransomware инциденти	20
2. Превенция на интернет-достъпни уязвимости	21
3. Компрометирани пароли	22
4. Phishing атаки	23
5. Други форми на Social Engineering	24
Какво да направим, ако станем жертва на ransomware атака?	25
Цитирани източници	27

Въведение

Рансъмуерът е вид зловреден софтуер, който представлява финалната фаза на една по-сложна кибератака – той криптира файлове и ограничава достъпа до дадена система, след като нападателят вече е проникнал в нея. Хакерът изисква откуп от потърпевшия, обикновено парична сума (в биткойн), в замяна ощетения си възвръща откраднатите данни. Най-често се използва биткойн или друга криптовалута, тъй като е трудно да бъде проследена. Ако жертвата откаже да заплати, всички файлове ще бъдат унищожени. Дори потребителят да заплати сумата не е сигурно, че хакерът няма да ги изтрие или да поиска повторно откуп.

В зависимост от откраднатата информация, потърпевшият може да бъде заплашен, че личната му информация ще бъде разпространена в интернет – местожителство, членове на семейство, банкова информация, документи, фирмена информация, работно място и т.н.

Откуп, комбиниран с злоупотреба с лични данни се нарича: „double extortion”. Колкото е по-силен мотивът, толкова е по-вероятно потърпевшият да се пречупи.

Друга тактика, която често се прилага е блъфиране. Киберпрестъпникът има частичен достъп до дадена система, но е неспособен да ѝ навреди. Тогава отправя безпочвени закани и разчита потребителят да изпълни указанията.

Тези атаки с изнудващ зловреден софтуер (ransomware) могат сериозно да нарушат бизнес процесите. Компаниите губят достъп до важна информация, необходима за нормалния работен процес и предоставяне на конкретни услуги. Икономическите щети за фирмите са значими, а възстановяването на репутацията след подобна атака е трудно и скъпо. Засегнати могат да бъдат организации от всякакъв мащаб. Щетите от ransomware атака рядко приключват с възстановяването на системите – последиците могат да се усещат дълго след това.

Компаниите трябва да провеждат задължителни обучения на служителите си, тъй като ransomware може да бъде свален през имейл, прикачени файлове, реклами, линкове, уеб страници с вложени злокачествени софтуери. В реферата, ще бъдат разгледани стратегии и защиты от ransomware. [1] [2]

История на Ransomware

Ransomware може да изглежда като съвременна заплаха, но идеята за кражба на данни, ограничаване на достъпа и искане на откуп съществува от десетилетия.

В края на 80-те години, киберпрестъпниците са криптирали файлове и са искали откуп в долари, изпратени по пощата. Една от първите документираните ransomware атаки е: “AIDS trojan (PC Cyborg Virus)”. Троянският кон е разпространяван чрез флопи дискети през 1989 година. Потърпевшите са принудени да изпратят 189\$ през пощенска кутия в Панама, за да възстановят достъпа до системите си. Методът за криптиране е бил сравнително прост – чрез симетрично криптиране. Симетричното криптиране е техника, при която един и същи ключ се използва за криптиране и декриптиране на данните.

Ransomware става широко разпространен от 2000 г. до настоящия момент. Преди 2000 г. киберпрестъпниците са имали затруднения при получаването на откуп. Появата на биткойна и криптовалутите променят това. Криптовалутите са лесен и удобен начин за получаване на крупната сума от потърпевшия, тъй като са трудно проследими. При традиционното банкиране участниците са ясно идентифицирани – име, банка, сметки, наличности, държава, регулации и т.н. При криптовалутите адресът на получателя на сметката не съдържа директна лична информация. Липсва и централизиран контролен орган. Почти невъзможно е преводите да бъдат спрени, замразени, върнати или проследени от институциите. „Изпирането“ на валутата е сравнително лесно – чрез т.нар. chain hopping (прехвърляне между различни криптовалути) и използване на privacy coins. Отрицателната страна на биткойна е, че не всеки потърпевш е достатъчно запознат как да го предостави, за да си върне информацията. Някои от компютърните престъпници са разкрити и заловени, защото са провеждали видеоконференции, на които са показвали на засегнатите как да предоставят биткойна.

През 2013 г. се появява CryptoLocker, което бележи повратен момент в развитието на ransomware. Този нов вид изнудващ зловреден софтуер използва плащания чрез Bitcoin и прилага по-съвременни криптографски методи. За целта са прилагани 2048-bit RSA двойка ключове – генерирани от командно-контролен сървър и изпращани към пострадалия. [3]

Еволюция на Ransomware

1. Ранна фаза на Ransomware

Първичната форма на софтуера за изнудване е, както вече споменахме, инфектирани флопи дискове. На фигура 1 е показано съобщението, което се визуализира на системата, афектирана от троянския кон - AIDS trojan (PC Cyborg Virus). AIDS заменя AUTOEXEC.BAT файла, който по-късно се използва да преброи колко пъти компютърът е стартиран. Когато броячът достигне до 90, AIDS скрива всички директории и криптира имената на всички файлове, намиращи се на **C:** драйв. Съответно се появява и съобщението за откуп. [3]

Dear Customer:

It is time to pay for your software lease from PC Cyborg Corporation. Complete the INVOICE and attach payment for the lease option of your choice. If you don't use the printed INVOICE, then be sure to refer to the important reference numbers below in all correspondence. In return you will receive:

- a renewal software package with easy-to-follow, complete instructions;
- an automatic, self-installing diskette that anyone can apply in minutes.

Important reference numbers: A5599796-2695577-

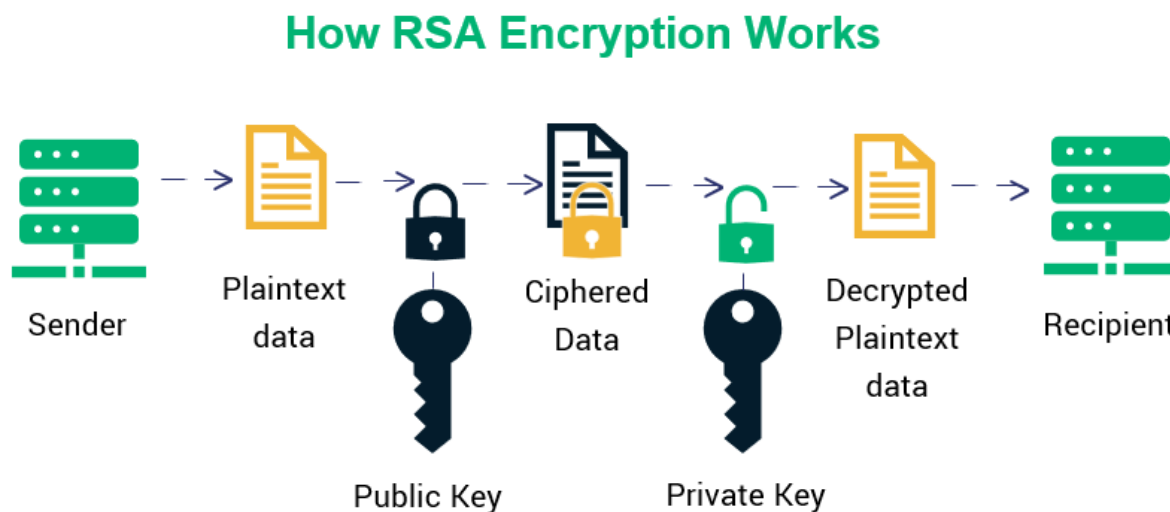
The price of 365 user applications is US\$189. The price of a lease for the lifetime of your hard disk is US\$378. You must enclose a bankers draft, cashier's check or international money order payable to PC CYBORG CORPORATION for the full amount of \$189 or \$378 with your order. Include your name, company, address, city, state, country, zip or postal code. Mail your order to PC Cyborg Corporation, P.O. Box 87-17-44, Panama 7, Panama.

Press ENTER to continue

Фигура 1: Съобщение за откуп на AIDS trojan.

2. Ransomware използващ RSA криптиране

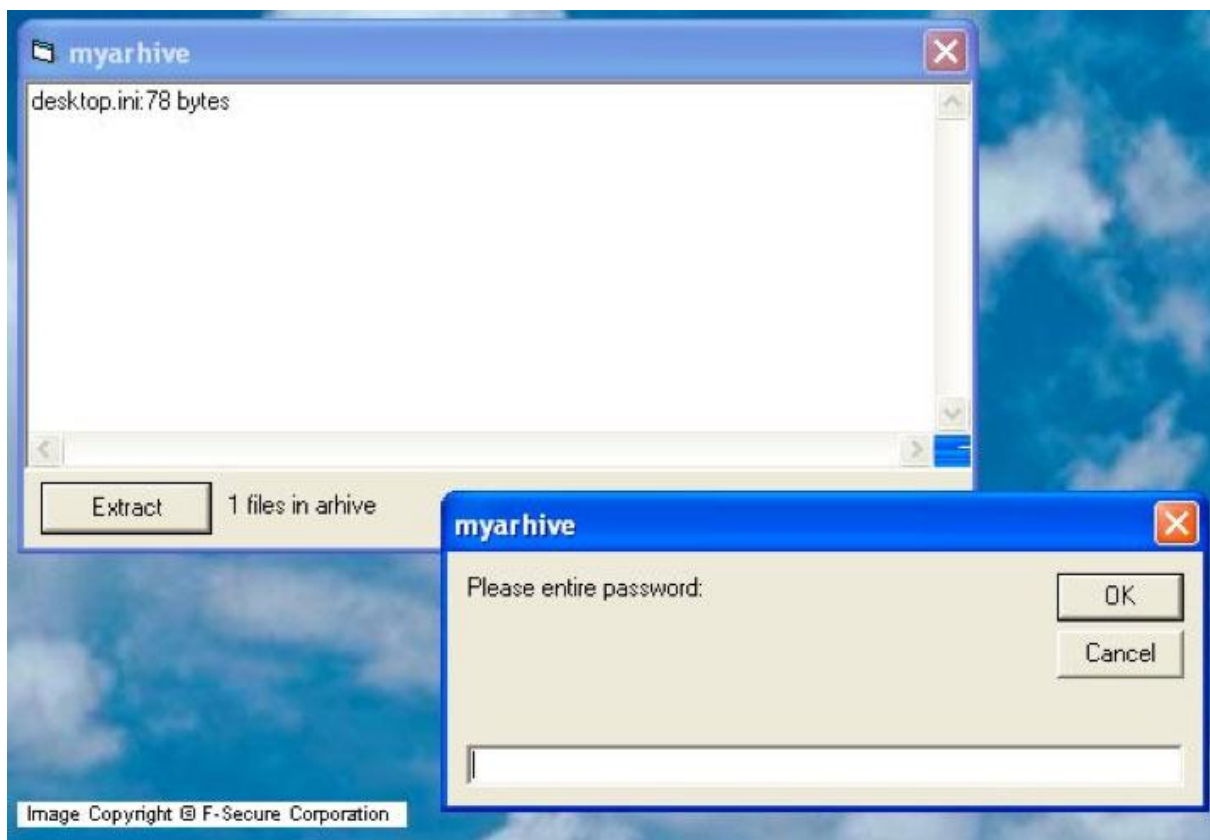
През 2004-2005 г. се появява нова форма на ransomware. Към вирусите се прилагат по-силни криптиращи алгоритми. Archiveus Trojan е първият вирус, който използва асиметричен алгоритъм за криптиране на данни – RSA (фиг. 2). [4]



Фигура 2: Архитектура на RSA криптиране.

Алгоритъмът използва два ключа, чрез които се криптира и декриптира информация. Основната идея е: разполагайки с единия ключ да е много трудно математически да бъде изчислен какъв е другият. По този начин става възможно свободното използване на единия от ключовете като "публичен", а другият да остане "таен" (само собственикът го притежава и никой друг не може в разумно време да го намери). В конкретния случай хакерът играе роля на собственик, който притежава частния (тайния) ключ. На практика файловете се криптират по начин, който не позволява възстановяване без заплащане на откуп. [5] [6]

Archiveus Trojan криптира всичко в MyDocuments директорията (фиг. 3) и изисква от потърпевшия да закупи артикули от онлайн аптека, в замяна ще получи 30 символен код, за да възстанови всичките си файлове. Известен „недостатък“ на вируса е, че дори пострадалият да заплати откупа, някои от файловете остават безвъзвратно увредени. [4]



Фигура 3: Изглед на Archiveus Trojan вирус.

3. Spear phishing Ransomware

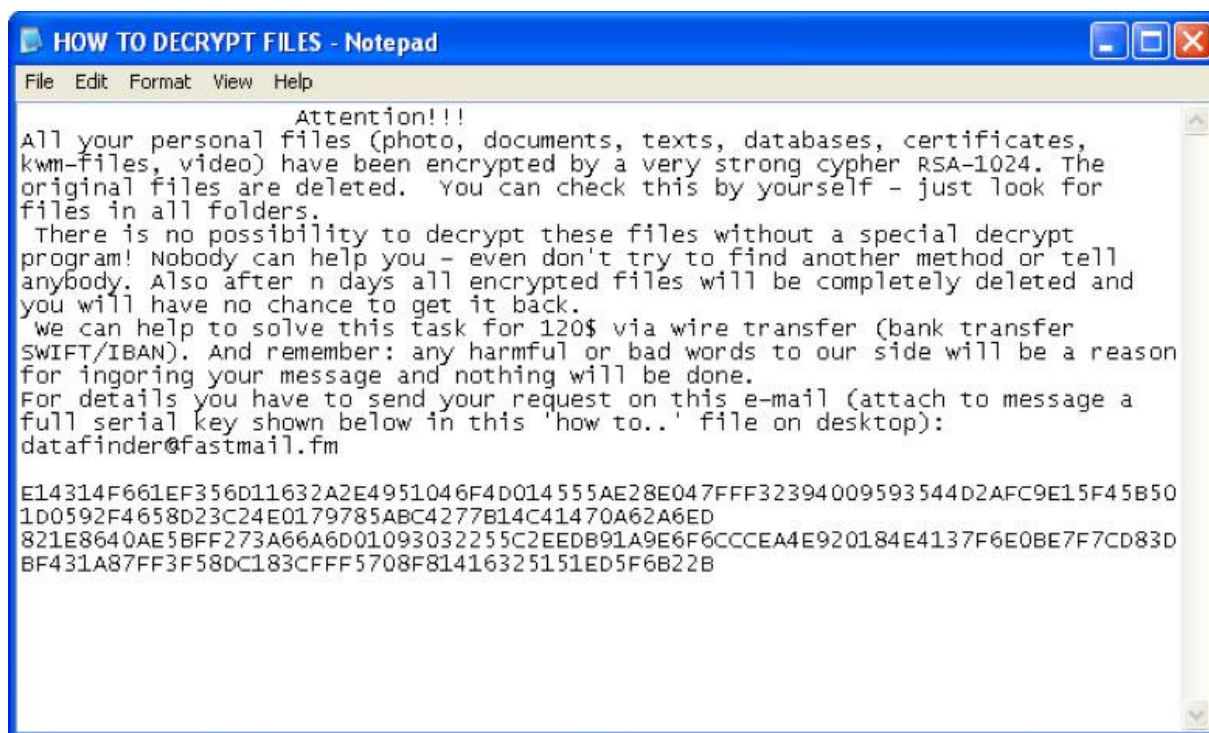
Spear phishing е вид phishing атака, при която се таргетира точно определен човек, група или организация. Целта е извличане на лична информация, сваляне и инсталация на вируси или изпращане на определена сума капитал до престъпниците. Постигат целите си чрез изграждане на фалшиви истории или сценарии. Фишинг заплахите са прикачени в имейли, социални мрежи, текстови съобщения или телефонни разговори. Spear phishing атаката е най-ефективната форма на атака, понеже измамата е пригодена да бъде максимално убедителна за конкретно лице. [7]

През 2006 година се появява първият spear phishing ransomware. GPCode се разпространява през електронни пощи като прикачен файл под формата на заявление за работа. Променя се тапета на десктопа, като е изписано съобщението, че системата е пробита и че е прикачен файл с инструкции (фиг. 4 и 5).

По-новите версии (2010 г.) използват алгоритъм за криптиране RSA-1024, който за времето си е непосилен да бъде разбит чрез brute force. Първите версии на GPCode използват симетрично криптиране, където ключът за криптиране и декриптиране е един и същ. Това го прави лесен за разбиване. Друг недостатък на първоначалния GPCode е, че файловете, които се криптират се запазват на нова локация, а некриптираните се изтриват. *Undeletion utility* може да възстанови част от файловете. [8]



Фигура 4: Пробита система от GPCode.

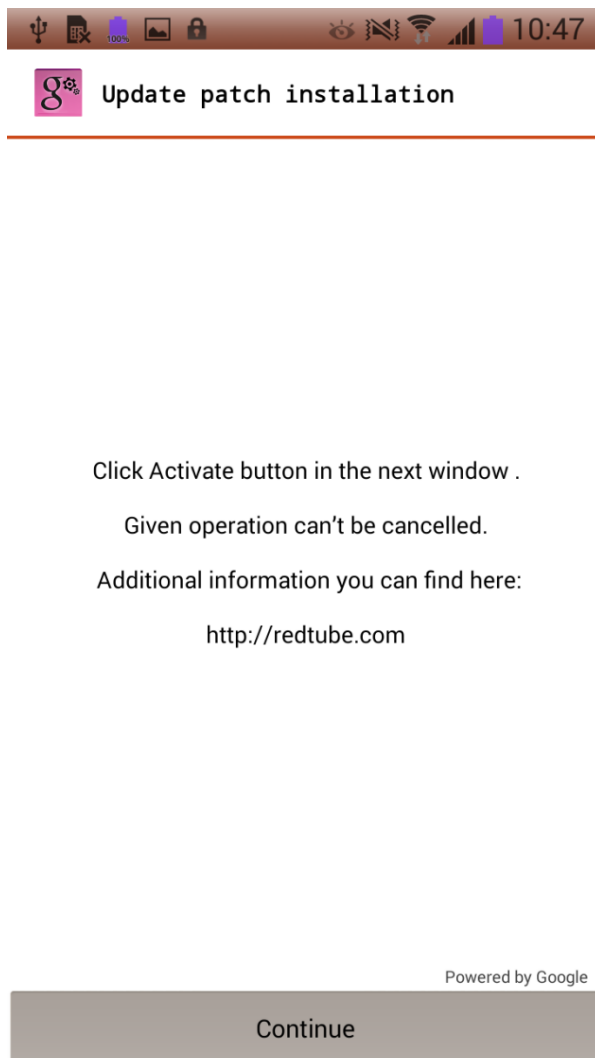


Фигура 5: Инструкции за откуп, GPCode.

4. Ransomware в Android базирани системи

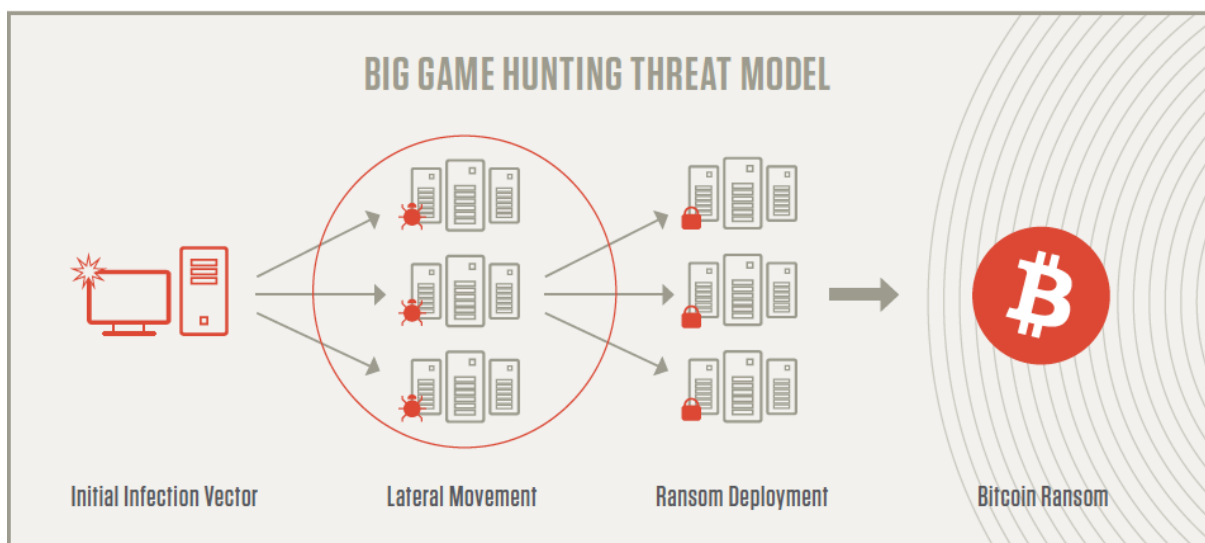
LockerPin е първият malware, който атакува мобилни системи. Потребителят инсталира мобилно приложение от пиратски сайтове, но към него се промъква и троянския кон – LockerPin. Троянският кон се опитва да получи административни правомощия, маскирайки се като софтуерен ъпдейт на телефона (фиг. 6). Ако потребителят се подведе и изпълни указанията, се сменя PIN кода на телефона.

Единственият начин да си възстанови достъпа е, ако мобилното устройство се преинсталира обратно до фабрични настройки. Това означава пълно изтриване на данните на устройството. PIN кодът е неизвестен дори и на хакера, тъй като е случайно генерирано число, следователно откупването е безполезно.



Фигура 6: Троянски кон, маскиран като софтуерен ъпдейт.

5. Big Game Hunting (BGH) и Ransomware



Фигура 7: Модел на заплахите в Big Game Hunting.

Ransomware операторите променят стратегията си за създаване на по-силни атаки. Те се отказват от метода „spray and pray“, при който зловредният софтуер се разпространява масово без конкретен избор на потърпевш. Вместо това започват да таргетират конкретни организации и потребители, което е известно още като Big Game Hunting.

При „spray and pray“ метода киберпрестъпниците получат малка сума откуп – стандартно по 300 долара, защото таргетират случайни хора. От друга страна, при Big Game Hunting откупите достигат десетки хиляди долара, защото на риск са изложени подбрани компании и обекти. Такива жертви са River Beach и TravelEx, заплатили съответно 600 хил. долара и 2.3 млн. долара. Атаката и в двата примера е една и съща - изтегляне на неверифицирани файлове през phishing имейл.

На фигура 7 е показан модела на атаката в BGH. Започва през едно инфектирано устройство и се разпространява към всички възможни системи в мрежата. Процесът се повтаря, докато се заразят възможно най-много системи. Следва deploy на ransomware и се изисква откуп в биткойни.

Ransomware в България

През 2025 г. Върховният административен съд на България (ВАС) става жертва на рансъмвер атака, известна още като: „White Rabbit“ (бял заек). „Белият заек“ е малък по-размер (около 100 KB) и не е прихванат от антивирусната система. За да започне атаката трябва да бъде въведена парола, която е известна само на хакерите. При активиране, криптира файловете, изключва системните папки на Windows и уведомява потребителите, че са обект на атака.

Атаката срива за седмици единната деловодна информационна система, използвана от всички административни съдилища по страната. Причина за атаката е най-вероятно човешка грешка – отваряне на съмнителен имейл, след което вируса се разпространява из цялата мрежа, оставайки незабелязан. Киберпрестъпниците успяват да криптира голяма част от наличната информация. Прилагат и двойно изнудване в биткойн – откуп едновременно за декриптиране и за непубликуването на информацията в интернет. Единствените устройства, които остават невредими са тези, които не са били включени в интернет мрежата. Не е известно дали ВАС е заплатил откупа, но Висшият съдебен съвет гласува близо 1.6 млн. лева за закупуването на нови сървъри. [9] [10] [11]

Ролята на AI в Ransomware атаките

Използването на изкуствен интелект (ИИ) открива нов фронт в продължаващата борба срещу Ransomware. Като security експерти, така и киберпрестъпници използват тази технология, за да подобрят своята производителност.

С навлизането на ИИ броят хакери се е увеличил значително. AI се използва за създаване на нови по-персонализирани тактики, използва се за експлоатация на уязвимости и откупите са станали още по-големи като сума. Ransomware атаките достигат рекордни върхове последните две години и е много вероятно изкуственият интелект да продължи тази тенденция през 2026 г.

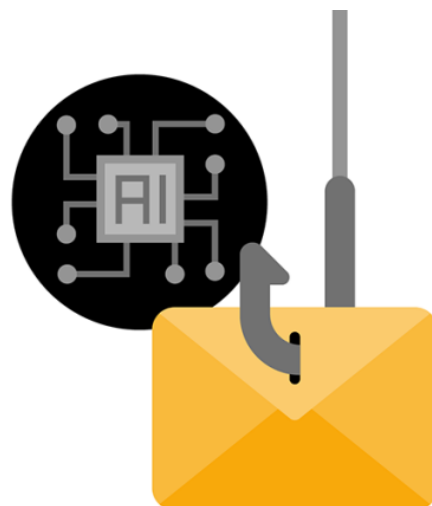
Киберпрестъпниците използват AI за автоматизация на стратегии за изграждане на ransomware, което позволява бързо идентифициране на уязвимости и внедряване на силно персонализирани фишинг кампании. [12]

Ето някои от начините, по които хакерите използват AI:

- Полиморфен AI ransomware - Традиционното разпознаване на ransomware атаки разчита на методи за детекция на често използвани модели. За да избегнат евентуална детекция, към ransomware се прилага AI, който непрестанно модифицира кода си, за да избегне разпознаване от антивирусни програми.
- Автоматизация: AI позволява на хакерите да автоматизират и персонализират производството на ransomware. Инструментите за автоматизация позволят бързо сканиране на уязвимости, ефикасно изпълнение на атаки и адаптация в реално време въз основа на защитните механизми. Това позволява множество атаки на различни организации едновременно.

40%
of phishing emails
targeting businesses
are now AI-generated

 blackfog.com



Фигура 8: 40% от фишинг атаките са генерирани от AI

Имплементация на Ransomware

За имплементацията на ransomware е използван Java 21 и Spring Framework. Целта на имплементацията е да се покаже колко лесно може да се създаде софтуер за симетрично криптиране и декриптиране на файлове, който да бъде използван за ransomware атаки. Такъв тип атака е прилаган в началото на XXI век.

В демото има три текстови файла. При стартиране на приложението се криптират и когато потребителят „плати“, тогава се декриптират обратно в текстови.

```
<dependencies>
  <dependency>
    <groupId>org.springframework.security</groupId>
    <artifactId>spring-security-crypto</artifactId>
    <version>6.4.2</version>
  </dependency>
  <dependency>
    <groupId>org.projectlombok</groupId>
    <artifactId>lombok</artifactId>
    <version>1.18.36</version>
    <scope>provided</scope>
  </dependency>
  <dependency>
    <groupId>ch.qos.logback</groupId>
    <artifactId>logback-classic</artifactId>
    <version>1.5.16</version>
  </dependency>
</dependencies>
```

Фигура 9: Използвани dependencies в pom.xml.

От *spring-security-crypto* е използван интерфейса *TextEncryptor* и класа *Encryptors*. Интерфейсът се използва за симетрично криптиране на стрингове.

```
public interface TextEncryptor {
    String encrypt(String text);
    String decrypt(String encryptedText);
}
```

Фигура 10: Интерфейс *TextEncryptor*.

```
public static TextEncryptor text(CharSequence password, CharSequence salt)
{
    return new HexEncodingTextEncryptor(standard(password, salt));
}
```

Фигура 11: Метод от класа, който се използва в демото.

Използва password-based криптиране, като се генерира ключ от паролата и солта. Паролата не трябва да бъде споделяна с никого, но в демото е показана за демонстративни цели. Солта е произволна стойност за защита срещу rainbow table атаки. Накрая се криптира текста и се връща като hex низ. [13]

Създаден е клас *TextFileService*, който се използва за прочитане и криптиране/декриптиране на горепосочените три текстови файла.

```
@Slf4j
public class TextFileService {

    private static final String SUFFIX = ".txt";
    private static final Path TARGET_FOLDER = Path.of("target_files");

    private static final String PASSWORD = "SPOOKY_SECRET_ATTACK";
    private static final String SALT = "abcdef1234567890";

    private final TextEncryptor encryptor = Encryptors.text(
        PASSWORD, SALT
    );

    public void encryptAll() throws IOException {
        for (var file : getTxtFiles()) {
            var content = Files.readString(file.toPath());
            var encrypted = encryptor.encrypt(content);
            Files.writeString(file.toPath(), encrypted);
            log.info("[ENCRYPTED] {}", file.getName());
        }
    }

    public void decryptAll() throws IOException {
        for (var file : getTxtFiles()) {
            var content = Files.readString(file.toPath());
            var decrypted = encryptor.decrypt(content);
            Files.writeString(file.toPath(), decrypted);
            log.info("[DECRYPTED] {}", file.getName());
        }
    }

    private List<File> getTxtFiles() {
        var files = TARGET_FOLDER.toFile()
            .listFiles(
                (dir, name) -> name.endsWith(SUFFIX)
            );
        return files != null ? Arrays.asList(files) : List.of();
    }
}
```

Класът използва анотацията `@Slf4j` за логване. Има четири константи, описващи какви са файловете, директорията им, паролата и солта. Създава се инстанция на `TextEncryptor`. Частният метод `getTxtFiles()` се ползва за намирането на трите текстови файла в "target_files" директорията. Методите `encryptAll()/decryptAll()` извикват `getTxtFiles()` метода и за всеки файл правят прочит, криптират или декриптират като презаписват съдържанието на файловете*.

*Освен този клас е създаден и *UI* клас, който не е разгледан в демото.

Демонстрация на Ransomware

Съдържание на текстовите файлове преди криптирането:

This is my secret document with important information.

Фигура 12: document1.txt

Another file with sensitive data that needs protection.

Фигура 13: document2.txt

Personal notes and passwords (just kidding, this is a demo).

Фигура 14: notes.txt

Стартиране на демото:

```
22:47:58 INFO  =====  
  
RANSOMWARE SIMULATOR (Educational)  
  
=====
```

Press Enter to simulate attack...

Фигура 15: Какво се визуализира първо на потребителя

```
22:51:03 WARN  SIMULATING RANSOMWARE ATTACK...  
  
22:51:03 INFO  [ENCRYPTED] document1.txt  
  
22:51:03 INFO  [ENCRYPTED] document2.txt  
  
22:51:03 INFO  [ENCRYPTED] notes.txt  
  
22:51:03 ERROR =====  
  
YOUR FILES HAVE BEEN ENCRYPTED!  
  
Pay the ransom to recover your files.  
  
=====
```

Pay now? (yes/no) :

Фигура 16: Симулация на атаката. Файловете са криптирани. Потребителят трябва да потвърди, че е заплатил.

```
2f0ba80edcf69430742e40ef970a177253163e83b1df0cf55b790bcd73f0959b1648c43caef  
d68b214eal1f6e16f50f80ef119ce88a1bf647ee8fd202ed0ce674b5be6ec4069d287f71e267  
c967d1000d
```

Фигура 17: document1.txt след криптирането.

```
8d4171026f8b8bfc0dbc4499590e8e70a52e62a622526462caa0c749f1dbd48d713c5dc3123  
751cf69b6d900e0f686da7a4ab9177a094bde6bdc22c8c4c930de5cd39fd133fa1d0c8b0186  
c8c7434d75
```

Фигура 18: document2.txt след криптирането.

```
2a26c3af01b7a5aad14a4c420b4ac559c120a940d49f048dd20290b018190722081e07e5201  
08b1c635a94d054450b1243d7df61d0ced553cf9e9ca384b2da5962cc7792ba7fcab0ec25a1  
5342ea3632
```

Фигура 19: notes.txt след криптирането.

Потърпевшият е заплатил откупа:

```
Pay now? (yes/no): yes
```

```
22:59:07 INFO Payment confirmed. Decrypting files...
```

```
22:59:07 INFO [DECRYPTED] document1.txt
```

```
22:59:07 INFO [DECRYPTED] document2.txt
```

```
22:59:07 INFO [DECRYPTED] notes.txt
```

```
22:59:07 INFO Decryption complete!
```

Фигура 20: Файловете са възстановени.

```
This is my secret document with important information.
```

Фигура 21: document1.txt след декриптирането.

```
Another file with sensitive data that needs protection.
```

Фигура 22: document2.txt след декриптирането.

```
Personal notes and passwords (just kidding, this is a demo).
```

Фигура 23: notes.txt след декриптирането.

QR code към имплементацията:



Стратегии и защита от ransomware

1. Подготовка за Ransomware инциденти

Подготовката включва създаване и поддържане на офлайн криптирани резервни копия на критично важната информация, както и редовна проверка на тяхната изправност. От съществено значение е резервните копия да се съхраняват офлайн, тъй като повечето ransomware атаки се опитват да открият и унищожат или криптират наличните архиви на системата, с което принуждават потърпевшия да плати откуп.

Важно е също така да се поддържат актуални images на системата със предварително конфигурирана операционна система и съответните софтуерни приложения. Това значително улеснява и ускорява възстановяването и повторното пускане в експлоатация на системата след атака.

Препоръчително е и поддържането на резервен хардуер, който да бъде използван при нужда. Това позволява по-бързо възобновяване на дейността в случаите, когато възстановяването на основната инфраструктура е нежелано или невъзможно.

Използване на *multi-cloud solution* е подходящо, защото може да се съхранява важна информация или резервни копия на системата. Това добавя още един слой защита. *Multi-cloud* е препоръчителен, тъй като намалява риска от *vendor lock-in* или с други думи организацията не зависи само от един доставчик на cloud. В случай че всички акаунти или услуги при даден облачен доставчик бъдат компрометирани, наличието на резервна инфраструктура при алтернативен доставчик позволява по-бързо възстановяване на системите.

Една от ключовите мерки за защита е въвеждането на Zero Trust Architecture (ZTA), която не допуска неоторизиран достъп до данни и услуги. Достъпът до данните трябва да бъде възможно най-гранулярен. Тоест необходимо е създаването на различни роли, които дават правомощия към определени данни и за определен срок. Така се избягват проблеми, при които потребителите имат пълни правомощия към всяка една услуга. Свързването към частна мрежа не е достатъчно безопасно. Права се дават само при необходимост. [1]

2. Превенция на интернет-достъпни уязвимости

Употребата на услуги като *Remote Desktop Protocol* в интернет е силно непрепоръчителна. *Remote Desktop* представлява свързване на даден потребител към отдалечена среда през интернет. Ако употребата на услугата е наложително е важно да се вземат превантивни мерки към често срещани първоначални векторни атаки (фиг. 24). Всички ненужни OS апликации и network протоколи трябва да са забравени. Честата проверка за уязвимости също е от ключово значение. Задължително е да се извършват редовни сканирания за уязвимости, като приоритет трябва да получат устройствата с директна връзка към интернет.

Чести ъпдейти и пачове на софтуера и операционната система към последните налични версии е ключово. Трябва да се приоритизира ъпдейти на OS свързани с процесването на интернет данни – уеб браузери и плъгини.

Малкият и средният бизнес често имат проблем с поддръжката на актуализациите, поради липса на security и maintenance отдел. Едно решение е да се премине към managed cloud providers, за да не се налага поддръжка на exchange server, identity server и mail gateway. Cloud providers следи и за уязвимости, пачва системи и има защиты против DDOS атаки.

Всички on-premise, облачни, мобилни и лични устройства трябва да са правилно конфигурирани и функциите за сигурност да са активни. Необходимо е да се спрат всички портове и протоколи, които не се предназначени за бизнес употреба (фиг. 9). [1]

NO EXPLOITABLE SERVICES ON THE INTERNET				PR.AC-3
OUTCOME		RECOMMENDED ACTION		
Unauthorized users cannot gain an initial system foothold by exploiting known weaknesses in public-facing assets.		Assets on the public internet expose no exploitable services, such as remote desktop protocol. Where these services must be exposed, appropriate compensating controls are implemented to prevent common forms of abuse and exploitation. All unnecessary OS applications and network protocols are disabled on internet-facing assets.		
TTP or RISK ADDRESSED	SCOPE			
- Active Scanning - Vulnerability Scanning (T1595.002) - Exploit Public-Facing Application (T1190, ICS T0819) - Exploitation of Remote Service (T1210, ICS T0866) - External Remote Services (T1133, ICS T0822) - Remote Services - Remote Desktop Protocol (T1021.001)	IT and OT assets on the public internet			

Фигура 24: Диаграма описваща превенция на internet-facing vulnerabilities. Експлоатация на услуги.

LIMIT OT CONNECTIONS TO PUBLIC INTERNET				PR.PT-4, PR.AC-5
OUTCOME		RECOMMENDED ACTION		
Reduce the risk of threat actors exploiting or interrupting OT assets connected to the public internet.		No OT assets are on the public internet, unless explicitly required for operation. Exceptions must be justified and documented, and excepted assets must have additional protections in place to prevent and detect exploitation attempts (such as logging, MFA, mandatory access via proxy or other intermediary, etc.).		
TTP or RISK ADDRESSED	SCOPE			
- Active Scanning - Vulnerability Scanning (T1595.002) - Exploit Public-Facing Application (T1190, ICS T0819) - Exploitation of Remote Service (T1210, ICS T0866) - External Remote Services (T1133, ICS T0822)	OT assets on the public internet			

Фигура 25: Диаграма описваща превенция на internet-facing vulnerabilities. Ограничаване на достъпа.

3. Компрометирани пароли

Задължителна имплементация на *Multi Factor Authentication (MFA)* за всички услуги, особено имейли, VPNs и акаунти, които имат достъп до важни системи. Ескалация към отговорните лица, когато дадена система е установена, че не позволява MFA или има потребители, които не използват MFA. Съвременните MFA заменят процеса с двете пароли към автентикация с пръстов отпечатък, лицево разпознаване, PIN на устройството или криптографски ключ.

Имплементация на Identity and Access Management (IAM) системи, за да могат администраторите да наблюдават и менажират роли, да следят достъпа до мрежи на on-premise и cloud базирани приложения.

Подмяна на административните пароли преди продукта да е пуснат на пазара. При разработката на дадена услуга/апликация, програмистите използват пароли, които са известни на целия екип, за да си улеснят работния процес. Това е приемливо, когато продуктът не е деплойнат и само се тестват функционалностите му. Ако тези пароли останат в кода, тогава хакерът има backdoor (фиг. 10). Същото важи и за umask 000 или подобен, където дава твърде много правомощия за четене, изпълнени и писане върху файловете. Акаунти с root access които се използват за ежедневни задачи също попадат в тази категория.

Независимо дали става въпрос за лични акаунти или фирмени, необходимо е една парола да бъде поне 15 символа. Използването на Password managers е препоръчително, ако потребителят има проблем с запомнянето на паролите. Не трябва пароли да се съхраняват в текстови файлове в устройствата. Не е добре паролите да се съхраняват в браузера.

Имплементация на заключване на акаунти при множество неуспешни опити. Логване и мониторинг на опитите за логин е необходимо за разпознаване на brute force атаки.

Токени и други private keys трябва да се помещават в vaults. Задължително е използването на силно хаширащи алгоритми. Едно такова решение е имплементацията на HashiCorp Vault. Vault е система за чувствителна информация – пароли, API ключове, токени, SSH ключове, TLS сертификати и др. Решава проблема на hardcoded пароли, споделени пароли, частни ключове в гит и ръчна ротация. Данните в vault са криптирани, има контрол до достъпа и audit логове. Поддържа LDAP, OIDC, IAM и много други. [1]

CHANGING DEFAULT PASSWORDS		PR.AC-1
OUTCOME		RECOMMENDED ACTION
Prevent threat actors from using default passwords to achieve initial access or move laterally in a network.		An enforced organization-wide policy and/or process that requires changing default manufacturer passwords for any/all hardware, software, and firmware before putting on any internal or external network. This includes IT assets for OT, such as OT administration web pages.
TTP or RISK ADDRESSED	SCOPE	In instances where changing default passwords is not feasible (e.g., a control system with a hard-coded password), implement and document appropriate compensating security controls, and monitor logs for network traffic and login attempts on those devices. OT: While changing default passwords on an organization's existing OT requires significantly more work, we still recommend having such a policy to change default credentials for all new or future devices. This is not only easier to achieve, but also reduces potential risk in the future if adversary TTPs change.
- Valid Accounts - Default Accounts (T1078.001) - Valid Accounts (ICS T0859)	Password-protected IT assets and newly acquired OT assets.	

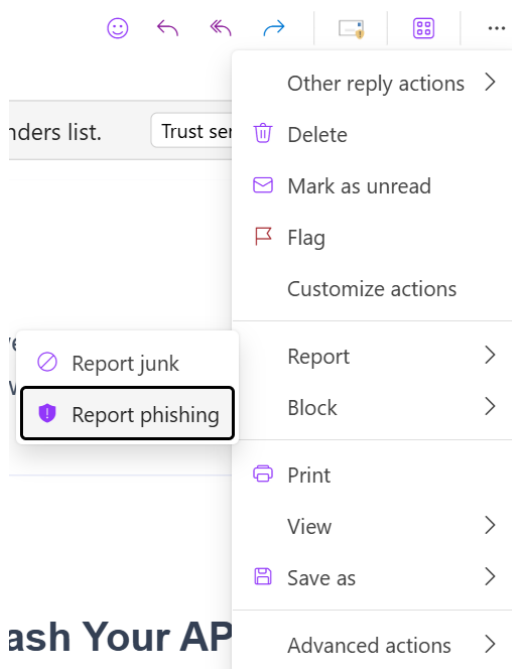
Фигура 26: Диаграма защо използването на пароли по подразбиране не е препоръчително.

4. Phishing атаки

Потребителят трябва да бъде много внимателен към какви платформи, уеб сайтове, форуми използва своя имейл адрес. Това е и най-лесният начин да стане обект на фишинг атака. Почти всички фишинг имейла носят чувство на тревожност, карат потребителя незабавно да предприеме някакви действия в противен случай, ще се случи Х събитие. Има няколко основни стъпки, по които може да се разпознае дали даден имейл е фишинг или не:

- Чувство на тревожност
- Липсва обръщение към получателя – това не винаги е приложимо, ако потребителят е таргетиран може да припознае и лична информация свързано с него.
- За първи път потребителят получава имейл от даден user – задължителна проверка на имейл адреса. Някои имейли имитират тези на големи организации, но има минимална и леко забележима разлика в адреса.
- Ако идва към служебен имейл – тогава да се провери дали е internal или external

При каквото и да е съмнение за фишинг имейл е важно потребителят да го репортира за фишинг (фиг. 11). Обикновено потребителят получава обратна връзка дали са предприети действия. [7] [14]



Фигура 27: Показва как се репортира фишинг имейл в Outlook.

5. Други форми на Social Engineering

Social Engineering е тактика използваща манипулация, насърчаване или измама целяща заблуждаване на жертва с цел придобиване на правомощия върху частна система, кражба на лична и/или финансова информация. Разчита на психологическа манипулация, за да надхитри потребителите да направят грешки или доброволно да дадат повелителна информация.

По-горе бяха разгледани типични phishing атаки, но те не представляват единствената форма на social engineering. Съществуват и други техники, които могат да бъдат използвани като начална точка при ransomware атаки:

- Scareware представлява атака, при която жертвата е тероризирана от фалшиви заплахи и несъществуващи заплахи. Потребителят е залъгван, че системата му е хакната и незабавно трябва да му бъде оказана помощ като се включват в неговото устройство чрез отдалечен достъп (remote access). Хакерът може да се представи като част от Security екип.
- Dumpster Diving представлява атака, при която мошеника е претърсил интернет за информация свързана с жертвата - банкова информация, студентска информация, социални мрежи – особено LinkedIn, където се съдържа информация за това къде живее жертвата, позицията, която заема, какво и къде е учил.
- Quid Pro Quo: Нападателят предлага услуги или помощ в замяна на чувствителна информация. Жертвата получава телефонно обаждане от непознато лице, които се представя като IT специалист и предлага техническа помощ. Също както Scareware, обикновено ще изискат от потърпевшия да инсталира някой скрипт или да му се предостави достъп до системата. [14]

Какво да направим, ако станем жертва на ransomware атака?

Най-важното е да се уведомят всички участниците в дадена мрежа. Независимо дали са част от организация или в домашна среда. В случай, че засегнатият е част от организация незабавно да се уведоми ръководството или отговорният екип. Много е важно да се уведомят всички засегнати клиенти и съответните власти.

Ето някои стъпки, които биха били полезни при подобна атака:

- Веднага да се определят засегнатите системи и да се изолират. Ако множество системи и/или subnets са компрометирани трябва да се изключат от мрежата. В случай, че това е невъзможно, да се изключат самите машини поотделно. С приоритет са най-критично важните системи.
- Друг вариант, ако не може да се изключат от мрежата е да се извади мрежовия кабел (ethernet) и да се изключат всички устройства свързани с Wi-Fi. Целта е да се ограничи разпространяването.
- За ресурси намиращи се в cloud да се направят snapshot-и на дисковете. Ще бъде от полза по-късно, когато се прави криминално разследване.
- След първоначалната атака киберпрестъпниците могат да имат достъп до вътрешните комуникации и да реагират на всяко едно предприето действие. За това комуникацията трябва да се извършва извънмрежово (out-of-band), например телефонни разговори.
- Смяна на всички идентификационни данни, задължително на пострадалите.
- Преди опит за възстановяване, първо да се направи пълни копия на засегнатите системи. Ще послужи в по-нататъшното разследване. Ако ще се възстановява от тях е важно да се направи проверка дали и те не са афектирани.
- Изключване на устройствата, ако по никакъв начин не могат да се изолират. Това вероятно ще унищожи и доказателства, понеже част от доказателствата се съхраняват и в RAM паметта. Да се прилага само в крайни случаи.
- Ако има системите, които не са засегнати, да се отделят.
- Прегледайте всички възможни системни, EDR, IDS, IPS логове.
- Ransomware е само финалната част, трябва да се прегледат по-ранни компроментации. Много е вероятно да има други dropped злонамерени софтуери. Трябва да бъдат отстранени преди възстановяване на системата.

- Всякакви новосъздадени акаунти, ескалирани привилегии или много често .exe файлове трябва да бъдат отстранени.
- Да се наблюдава изпълнението на PowerShell команди, използването на RMM софтуер, неочаквани комуникации по мрежата и извличане на идентификационни данни.
- Ако има неочаквано голям изходящ трафик, най-вероятно се извличат незаконно данни.
- За облачна инфраструктура да се провери дали на firewall-а не е зададено правило 0.0.0.0/0, което дава достъп на всеки от интернет да влезне. [1]

Цитирани източници

- [1] „#StopRansomware Guide,“ Americas Cyber Defense Agency, [Онлайн]. Available: <https://www.cisa.gov/stopransomware/ransomware-guide>.
- [2] „Ransomware,“ FBI, [Онлайн]. Available: <https://www.fbi.gov/how-we-can-help-you/scams-and-safety/common-frauds-and-scams/ransomware>.
- [3] K. Baker, „History of Ransomware,“ CrowdStrike, 09 10 2022. [Онлайн]. Available: <https://www.crowdstrike.com/en-us/cybersecurity-101/ransomware/history-of-ransomware/>.
- [4] „archiveus-trojan,“ Knowbe4, [Онлайн]. Available: <https://www.knowbe4.com/ransomware-knowledgebase/archiveus-trojan>.
- [5] Ф. Петров, „RSA,“ 16 02 2020. [Онлайн]. Available: <https://www.cphpvb.net/network-security/10840-rsa-with-example/>.
- [6] „What is RSA Asymmetric Encryption? How Does it Work?,“ Secure W2, 15 09 2025. [Онлайн]. Available: <https://www.securew2.com/blog/what-is-rsa-asymmetric-encryption>.
- [7] Matthew Kosinski, „Spear phishing,“ IBM, [Онлайн]. Available: <https://www.ibm.com/think/topics/spear-phishing>.
- [8] „Gpcode,“ Knowbe4, [Онлайн]. Available: <https://www.knowbe4.com/ransomware-knowledgebase/gpcode>.
- [9] „Човешка грешка пуснала "Белия заек" да хакне системата на ВАС,“ СЕГА, 30 01 2025. [Онлайн]. Available: <https://www.segabg.com/category-bulgaria/choveshka-greshka-pusnala-beliya-zaek-da-hakne-sistemata-na-vas>.
- [10] „„Бял заек“ атакувал ВАС. Как е допунат срывът?,“ FrogNews, 2025 01 30. [Онлайн]. Available: <https://frognews.bg/novini/bial-zaek-atakuval-vas-kak-dopunat-srivat.html>.
- [11] „Бял заек Ransomware,“ EnigmaSoft, [Онлайн]. Available: <https://www.enigmasoftware.com/bg/byalzaekransomware-otstranqvane/>.
- [12] B. Robb, „AI and Ransomware Prevention: How Smart Tech can Outsmart Cybercriminals,“ BlackFog, 24 06 2025. [Онлайн]. Available: <https://www.blackfog.com/ai-and-ransomware-prevention-how-smart-tech-can-outsmart-cybercriminals>.
- [13] „Spring Security Crypto Module,“ Spring, [Онлайн]. Available: <https://docs.spring.io/spring-security/reference/features/integrations/cryptography.html>.

- [14] C. M. University, „Social Engineering,“ [Онлайн]. Available:
<https://www.cmu.edu/iso/aware/dont-take-the-bait/social-engineering.html>.